

Scenario 04 — CRA control mapping (SIEM manufacturer)

The bridge between the **evidence bundle** shipped with this scenario and the **CRA framework as it is actually represented in CyberFort**.

Different from scenarios 1–3: those linked *findings* to CRA controls. This scenario is about a *manufacturer demonstrating conformity*, so this document links **evidence artefacts** to CRA controls instead.

How the CRA framework is structured in CyberFort

CRA framework structure in CyberFort

Each level is browsable in the platform under Frameworks → CRA.

CRA — Cyber Resilience Act (built-in framework)

Chapter I — General provisions

- Articles 1, 2, 6

Chapter II — Economic operators

- Articles 13, 14, 25, 26

Chapter III — Conformity

- Article 28 · Annex V

Chapter V — Market surveillance

- Articles 52, 54, 70

Annex I — Essential cybersecurity requirements

1

2

3a

3b

3c

3d

3e

3f

3g

3h

3i

3j

3k

Vulnerability Handling

VH-1

VH-2

VH-3

VH-4

VH-5

VH-6

VH-7

VH-8

CyberGuard SIEM Manager v1.0 is classified under CRA **Annex III Class II** — *important product with digital elements — security software (intrusion detection)*. This classification triggers:

- Full **Annex I** essential cybersecurity requirements (1, 2, 3a–3k).
- Full **Vulnerability Handling** requirements (VH-1 through VH-8).
- Conformity path:** internal audit + **notified-body review of the technical documentation** (Annex VII Module B/C).
- Support period of **60 months** (Article 13(8)).

Evidence bundle → CRA question mapping

`cyberguard-sbom.spdx.json` — Software Bill of Materials

SPDX 2.3 machine-readable SBOM covering the manager binary, Go standard library and Alpine base image.

CRA question (verbatim from seed)	Annex I objective
Q38 — "Do you identify and document vulnerabilities and components contained in your products with digital elements?"	VH-1 (component inventory + SBOM)
Q39 — "Do you draw up a software bill of materials in a commonly used and machine-readable format?"	VH-1
Q40 — "Does your software bill of materials cover at least the top-level dependencies of the products?"	VH-1

penetration-test-report.md — Independent penetration test

Black-box + grey-box test by Aegean Cyber Testing Ltd, June 2026.

CRA question	Annex I objective
Q1 — "Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?"	1 (designed to ensure appropriate level of cybersecurity)
Q13 — "Are your products with digital elements delivered without any known exploitable vulnerabilities?"	2 (no known exploitable vulnerabilities)
Q20 — "Do you ensure protection from unauthorized access by appropriate control mechanisms?"	3b (protection from unauthorised access)
Q21 — "Do you implement authentication, identity or access management systems?"	3b
Q41 — "Do you apply effective and regular tests and reviews of the security of your products with digital elements?"	VH-3 (effective and regular security tests)

secure-development-lifecycle.md — SDLC + patch policy

Vendor's SDLC covering design → implementation → testing → release → post-release.

CRA question	Annex I objective
Q10 — "Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?"	VH-1
Q14 — "Are your products made available on the market with a secure by default configuration?"	3a (secure by default configuration)
Q16 — "Do you ensure that vulnerabilities can be addressed through security updates?"	3k (updates address vulnerabilities)
Q17 — "Are automatic security updates installed within an appropriate timeframe enabled as a default setting?"	3k
Q23 — "Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?"	3c (confidentiality)
Q25 — "Do you protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration?"	3d (integrity)

CRA question	Annex I objective
Q34 — "Do you provide security-related information by recording and monitoring relevant internal activity?"	3j (security-relevant info recording)

coordinated-vulnerability-disclosure-policy.md — CVD policy

Vendor's PSIRT contact, SLAs, disclosure procedure, and market-surveillance-authority contact.

CRA question	Annex I / Vuln-Handling objective
Q42 — "Once a security update is made available, do you share and publicly disclose information about fixed vulnerabilities?"	VH-4 (publicly disclose fixed vulnerabilities)
Q43 — "Do you provide a description of vulnerabilities, affected products, impacts, severity and remediation information?"	VH-4
Q44 — "Do you have a policy on coordinated vulnerability disclosure in place and enforced?"	VH-5 (coordinated disclosure policy)
Q46 — "Do you provide a contact address for reporting vulnerabilities discovered in your products?"	VH-6 (facilitate sharing of vulnerability info)

Annex I + Vulnerability Handling coverage matrix

Annex I obj.	Title (paraphrased)	Covered?	Evidence artefact
1	Designed for appropriate level of cybersecurity	✓	Pen-test report — STRIDE threat model
2	Delivered without known exploitable vulnerabilities	✓	Pen-test report — 0 critical, retests attached
3a	Secure by default configuration	✓	SDLC §2 — secure-coding checklist
3b	Protection from unauthorised access	✓	Pen-test — RBAC + MFA
3c	Confidentiality (encryption)	✓	SDLC — TLS 1.3 + mTLS
3d	Integrity protection	✓	SDLC — Sigstore-signed releases
3e	Data minimisation	partial	Trainee notes agent log-retention rules
3f	Availability / DoS resilience	partial	Pen-test out of scope for load testing
3g	Limit impact on other devices / networks	✓	SDLC — rate-limits on agent → manager comms
3h	Limit attack surfaces / external interfaces	✓	SDLC — mTLS-only agent registration

Annex I obj.	Title (paraphrased)	Covered?	Evidence artefact
3i	Reduce impact of incident (exploit mitigation)	✓	Alpine + non-root container user
3j	Security-relevant info recording	✓	The product is itself a SIEM
3k	Updates can address vulnerabilities	partial	Auto-updates on manager; agents pull on check-in (documented gap on Q17)
VH-1	Component inventory + SBOM	✓	SBOM (SPDX 2.3)
VH-2	Address & remediate without delay	✓	SDLC §5 — 7-day patch SLA for High/Critical
VH-3	Effective and regular security tests	✓	Pen-test + continuous fuzzing
VH-4	Publicly disclose fixed vulnerabilities	✓	CVD policy — Publication
VH-5	Coordinated disclosure policy	✓	CVD policy — main body
VH-6	Facilitate sharing of vulnerability info	✓	CVD policy — Contact
VH-7	Secure distribution of updates	✓	SDLC — Sigstore/cosign + secure channels
VH-8	Free-of-charge disseminated patches	✓	SDLC — patches free during 60-month support

Coverage summary: 18 of 21 Annex I + Vulnerability-Handling objectives are directly covered by the evidence bundle. Three are marked partial and should trigger a compensating-control note in the assessment:

- **3e** (*data minimisation*) — retention rules for agent logs need explicit documentation.
- **3f** (*availability / DoS resilience*) — load testing is not part of the pen-test scope; add before the notified-body review.
- **3k** (*automatic updates*) — the air-gapped-agent case (documented on Q17).

What the trainee actually clicks (assessment flow)

1. **Assessments** → **+ New Assessment** — Framework: **CRA** , Type: **Conformity** , Scope: **Asset / Product** → **CyberGuard SIEM Manager** .
2. **Open the assessment card** — the 52-question questionnaire opens.
3. **For each of the 16 target questions** in Step 3 of the handbook: pick the verdict, write the Evidence Description, click **Attach File(s)**, upload the matching artefact from **evidence/** , click **Save Answer** .
4. **Export PDF** from the toolbar — that PDF plus the four evidence files form the CRA technical documentation submission.

Why this matters in the proposal context

The CYBERFORT proposal targets SME manufacturers who face CRA obligations before placing products on the EU market. **CyberGuard Labs SME s.à r.l.** is exactly that profile — a small Cypriot vendor placing a security product (Annex III Class II) into the single market. Producing the CRA conformity pack end-to-end in an hour, with CyberFort orchestrating the questionnaire and evidence flow, is the entire value proposition of the platform for this audience.